

Autonomous Email Security Architecture for Balkan SMBs

Defending Legacy Local Infrastructure via Open-Source Sublime Security Integration, Zero-Configuration AI Frameworks, and Hybrid Webhook/IMAP Ingestion Architecture

EXECUTIVE SUMMARY

Small and Medium Businesses (SMBs) across North Macedonia and the broader Western Balkan region represent a systemic gap in global cybersecurity defenses. Reliant heavily on localized hosting providers (e.g., MKhost, Uhost) operating legacy cPanel/IMAP infrastructure, these organizations are highly vulnerable to targeted regional phishing, invoice manipulation fraud (Лажни фактури), and linguistic Business Email Compromise (BEC). Traditional enterprise email security solutions remain pricing-prohibitive and deployment-complex for this demographic.

This paper presents a next-generation technical blueprint for an asynchronous, zero-configuration email security gateway. By utilizing the MIT-licensed **Sublime Security Platform** as a core detection layer, our system eliminates intrusive MX-record modifications. It dynamically normalizes email payloads across multi-tenant environments (including traditional IMAP and native Microsoft Graph/Google APIs) into a universal Message Data Model. Evaluated by specialized Message Query Language (MQL) rules and localized AI classifiers tailored for South Slavic language contexts, this framework enables real-time threat clawbacks without compromising regional privacy and performance constraints.

Author:	Technology Strategy & Security Engineering Group
Market Target:	Western Balkans (North Macedonia, Serbia, Albania, region)
Date:	May 2026
Classification:	Technical White Paper • Version 2.0

1. Introduction & Regional Market Dynamics

The threat landscape for enterprise email communication has fundamentally shifted from macro-distributed malicious payloads to highly targeted, linguistically localized social engineering. In the Western Balkan region—specifically within North Macedonia—Small and Medium Businesses (SMBs) form the backbone of the domestic economy. However, these entities are disproportionately targeted by customized fraud schemes due to a combination of legacy architectural infrastructure and a lack of localized defensive solutions.

Enterprise-grade Secure Email Gateways (SEGs) provided by major tier-1 global cybersecurity firms are structurally ill-suited for this market due to three distinct friction points:

- **Economic Disconnect:** Per-seat enterprise licensing matrices fail to match regional SMB operational budgets.
- **Deployment Friction:** Standard solutions demand full MX (Mail Exchange) record authoritative DNS routing changes. SMBs running single-tenant local web hosting packages lack the internal IT resources to configure or maintain these adjustments safely.
- **Linguistic Blind Spots:** Global detection models are primarily optimized for English and major European languages. They routinely miss semantic threat profiles written in South Slavic languages (Macedonian, Serbian) and regional dialects that deploy localized terminology for state institutions and utilities.

1.1 The Dominance of Legacy Regional Hosting

Unlike Western corporate ecosystems dominated by native cloud platforms (Microsoft 365 and Google Workspace), a critical mass of Balkan SMBs host their corporate mail infrastructure via localized shared-hosting providers like MKhost, Uhost, or Inhost. These providers provide Linux environments running **cPanel** with local mail servers managed via standard **Roundcube** or **Horde** webmail interfaces. This structural reliance imposes explicit legacy transport protocols, notably IMAP (Internet Message Access Protocol) and SMTP, requiring security solutions to adapt directly to these constraints.

2. Targeted Threat Profiles in the Western Balkans

Attackers operating within the regional context bypass signature-based endpoint tracking by exploiting structural payment workflows common among Balkan suppliers. The primary vectors are categorized into three operational frameworks:

Threat Vector	Target Mechanism	Regional Specifics (Balkans)
Invoice Fraud	Man-in-the-middle or lookalike spoofing to supply chains intercepting payment terms.	Impersonation of critical utility entities (EVN Macedonia, Makedonski Telekom, A1, BEG) altering bank IBAN coordinates.

Threat Vector	Target Mechanism	Regional Specifics (Balkans)
(Лажни Фактури)		
Authority Scams (Државен Скам)	Coercive legal threats claiming to stem from state regulatory mechanisms.	Forged summons or non-compliance mandates from the UJP (Public Revenue Office) or MVR (Ministry of Internal Affairs).
Lookalike Domains (Слични Домени)	Slight typographical adjustments on standard domains to trick non-technical staff.	Exploiting top-level generic variations or cross-language lookalikes targeting the .mk or .com.mk naming conventions.

Because these emails lack binary payloads (such as malicious macro executables or known malicious scripts) and rely entirely on semantic coercion and clean text containing modified domestic bank details, traditional heuristic security rules fail to trigger alerts. Protection necessitates an architecture capable of deep semantic evaluation combined with real-time operational execution.

3. System Architecture & Detection Pipeline

The proposed platform implements a decoupled, API-first architectural model designed to isolate tenant mailboxes, extract message telemetry, and enforce defensive action logic at the edge. Rather than routing client MX records through an inline proxy gateway—which introduces latency, single-points-of-failure, and delivery friction—the system operates via asynchronous cloud APIs and direct mail server polling protocols.

The underlying detection and automated remediation engine is built upon the open-source **Sublime Security Platform** (licensed under MIT). This approach allows our system to ingest multi-tenant mail streams from fragmented regional hosting setups (e.g., cPanel/IMAP) as well as global cloud enterprise environments (Microsoft 365, Google Workspace).

Core Operational Law: Zero-Knowledge Data Transit Strategy

To preserve alignment with local personal data regulations and GDPR frameworks, credentials for legacy systems are subjected to immediate encryption at rest using AES-256-GCM. Decryption keys are confined within dedicated Hardware Security Modules (HSM) or cloud KMS layers, ensuring that clear-text customer credentials remain unexposed throughout runtime transit execution.

3.1 Automated Provider Discovery Pipeline

To bypass configuration friction, onboarding relies entirely on automated DNS MX parsing. Upon input of the enterprise email address (E_{addr}), the application isolates the target domain and evaluates its public mail exchangers. Let MX_{domain} be the primary resolved mail exchange server:

f(MX_{domain}) ightarrow egin{cases} ext{Microsoft 365 Webhook Pipeline} & ext{if } MX \in ext{.protection.outlook.com} \ ext{Google Workspace OAuth Pipeline} & ext{if } MX \in ext{*.google.com} \ ext{Asynchronous IMAP Worker Engine} & ext{otherwise (e.g., mail.*.mk)} \ end{cases}*

This discovery process occurs automatically on the backend, dynamically updating the frontend UI to display either an enterprise single-sign-on (SSO) button or a secure, self-configuring credential gateway.

3.2 Message Ingestion & Data Modeling

When a client connects their email environment to the dashboard, our orchestration layer programmatically provisions the endpoint inside a self-hosted, scalable cluster of the Sublime Platform via standard API commands.

1. **Extraction & Normalization:** Inbound messages are processed by Sublime’s core parsing system, translating raw, unformatted `.eml` or IMAP multi-part streams into a structured **Message Data Model (MDM)**.
2. **Telemetry Generation:** The MDM normalizes intricate aspects of the email payload, splitting out parameters such as sender authentications (SPF, DKIM, DMARC), deep header arrays, body URI structures, and attachment metadata properties into queryable nodes.

3.3 Detection-as-Code via Message Query Language (MQL)

Rather than relying exclusively on legacy, easily by-passable signature patterns or blacklists, Email Shield implements defensive rules utilizing **Message Query Language (MQL)**. MQL permits our engineering group to author complex, context-aware, behavioral queries that intercept attacks before execution.

To mitigate localized threat paradigms targeting the Balkan market—such as utility phishing or custom corporate impersonation scams—the MQL compiler screens for cross-heuristics combining language-specific triggers, attachment characteristics, and high-risk sender variables.

```
name: "Balkan Localized Invoice & Impersonation Variant"
type: "query"
severity: "high"
```

```
description: "Flags inbound communication attempting to mimic domestic utility structures
combined with transactional payment syntax and unknown historical sender states."
```

```
detection:
```

```
(
  // Scan for localized regional business vocabulary in plain/HTML bodies
  strings.ilike(body.plain, '*исплата*', '*фактура*', '*сметка*', '*плаќање*') or
  strings.ilike(subject, '*invoice*', '*platno*', '*racun*')
) and
length(attachments) > 0 and
(
  // Detect lookalike domains targeting regional infrastructure variants
  (
    strings.ilike(sender.email.domain, '*evn*', '*telekom*', '*a1*') and
    not sender.email.domain in ('evn.mk', 'telekom.mk', 'a1.mk')
  ) or
  // Intercept free-mail usage impersonating executive configurations
  (
    sender.display_name in $org_display_names and
    sender.email.domain in $free_email_providers
  )
)
```

3.4 Remediation & Multi-Tenant Feedback Loop

When an MQL evaluation yields a true match, the self-hosted engine fires an asynchronous webhook payload to our central backend service. The platform executes a two-phase action pattern:

- **Remediation Action:** The platform utilizes Microsoft Graph, Google API, or standard IMAP flags (via ImapFlow background daemons) to isolate the malicious artifact—shifting it into a restricted system Quarantine folder to minimize user interaction risk.
- **Telemetry Accumulation:** Incident components are sanitized and streamed into our multi-tenant data engine for real-time customer dashboard reporting, visibility auditing, and security orchestration analytics.

5. Deployment Strategy, Trust Validation & Legal Compliance

Launching an email security startup within the Western Balkan region requires a targeted approach that balances user trust with technological execution. The deployment plan splits into three distinct phases designed to maintain structural velocity while minimizing regulatory and capital liabilities:

1. **Phase 1: Local Ingestion MVP (B2B Focus):** Launch native IMAP workers using MIT components wrapped around our self-hosted Sublime infrastructure. This approach completely bypasses the restrictive

app verification barriers imposed by global tech platforms, enabling immediate market entry and cash-flow generation across local cPanel hosts (MKhost, Uhost).

2. **Phase 4: Microsoft 365 Integration & Regional Scaling:** Scale into corporate networks utilizing Microsoft Graph webhooks linked into the Sublime platform backend. Publisher identity validation is accomplished for free via standard business registry channels, completely bypassing expensive external security auditing costs.
3. **Phase 3: Deep Language Optimization & Google Compliance:** Implement customized local language models and initiate the structured security assessments needed to access broader consumer Gmail endpoints.

5.1 The Trust Blueprint for Local SMBs

Because the legacy IMAP architecture requires processing credentials for cPanel accounts, building user trust is paramount. The platform maintains market visibility through strict data isolation:

- **Infrastructure Isolation:** The core processing engine functions exclusively as a transient data broker. Email bodies are evaluated on the fly within localized RAM buffers and are never committed to permanent database disks.
- **Separation of Powers:** The system UI dashboard and the email connection managers run as completely separated microservices. If the web platform encounters a public-facing vulnerability, the core processing engine and database remain completely unexposed.

6. Conclusion

The architecture detailed in this white paper provides an elegant, highly protective, and low-friction security option tailored to the unique economic and structural realities of the Balkan SMB market. By combining modern Node.js automation with the enterprise-grade, MIT-licensed **Sublime Security Engine**, the platform bridges the gap between legacy mail frameworks and next-generation security. This approach creates a powerful, scalable, and highly defensible regional cybersecurity business model.